

# Retour de cellule — Risque / Conformité

**Réf.** : Réponse à la note DC/2026/01, rubrique 02 · 24 septembre 2026 (J2), 16:45, Europe/Paris (UTC+2)  
**Émetteur** : Cellule Risque / Conformité · répondante : Essafi Amina  
**Destinataire** : Reda El ghardegue, chef de cellule adjoint, Direction / Coordination  
**Copie** : Belkhaouad Aya, cheffe de cellule et répondante  
**Objet** : Obligations, engagements contractuels, données exposées et arbitrage rançon · Incident MIRAGE  
**Traitement** : **prioritaire**

## 01 Obligations à examiner au regard des faits établis

| Autorité             | Fondement                                                                                                                                                                         | Condition de notification                                 | Délai                                                                            | Informations manquantes                                                                                              |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------|----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|
| DGSSI / maCERT       | Loi 05-20, art. 8 : déclarer l'incident « dès qu'elle prend connaissance » ; art. 14 : applicable aux IIV ; art. 50 : amende 100 000–200 000 DH si manquement.                    | Incident avéré (A-01) ; AtlasGrid IIV ou entité publique. | <b>Sans délai</b> depuis J1 11:52. Aucun délai en heures dans la loi.            | Statut IIV d'AtlasGrid ; interlocuteur DGSSI (art. 6) ; référentiel DGSSI de déclaration (décret 2-21-406, art. 42). |
| CNDP                 | Loi 09-08, art. 23 : protéger les données contre « la diffusion ou l'accès non autorisé » ; art. 58 et 64 : sanctions. <b>Aucune obligation légale de notifier une violation.</b> | Données personnelles extraites (A-02, A-03).              | Pas de délai légal ; cible recommandée <b>72 h</b> (avant J4 14:27).             | Fichiers réellement sortis ; nombre de personnes ; traitements déclarés (art. 12).                                   |
| Personnes concernées | Loi 09-08, art. 3 : traitement loyal. Pas d'obligation explicite d'information.                                                                                                   | Risque confirmé pour salariés ou clients.                 | Dès que le périmètre est confirmé.                                               | Catégories de données exposées.                                                                                      |
| Assureur             | Code des assurances (loi 17-99), art. 20 : aviser l'assureur « au plus tard dans les cinq jours » de la survenance du sinistre.                                                   | Police couvrant le risque cyber.                          | <b>5 jours max</b> ; survenance possible dès J-1 → <b>déclarer aujourd'hui</b> . | Existence de la police ; garanties (extorsion, pertes d'exploitation) ; accord préalable exigé avant tout paiement.  |

## 02 Engagements envers les clients — Chérifiennne des Mines

| Point                    | Engagement déjà accepté ?                     | Analyse                                                                                                                                                                      |
|--------------------------|-----------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Disponibilité 99,5 %     | Invoquée par le client, non vérifiée.         | 99,5 % = environ 3,6 h d'arrêt par mois ou 43,8 h par an. Seuil déjà dépassé si la mesure est mensuelle. À lire : service couvert, période de mesure, exclusions, pénalités. |
| Rétablissement sous 24 h | <b>Non : c'est une demande nouvelle.</b>      | L'accepter créerait un engagement (DOC, art. 230 : le contrat fait la loi des parties). Aucun délai sans validation de Continuité et de la Direction.                        |
| Explication écrite       | Demandée ; clause de notification à vérifier. | Réponse factuelle, sans aveu de faute ni spéculation sur les données.                                                                                                        |
| Force majeure            | Non invoquée.                                 | DOC, art. 269 : exige un fait imprévisible rendant l'exécution impossible ; l'absence de MFA fragilise l'argument.                                                           |

## 03 Responsabilités contractuelles d'OasisNet

| Constat                                                                                                           | Fondement                                                                                                                                                                                                                                 | Informations manquantes                                                                                                    |
|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| svc_oasisnet utilisé sans MFA, la nuit, depuis l'étranger (A-02) ; même compte modifie la rétention Veeam (A-05). | Loi 09-08, art. 23 al. 2-3 : sous-traitant à « garanties suffisantes », contrat obligatoire ; <b>AtlasGrid reste responsable</b> envers la CNDP et les personnes. Loi 05-20, art. 10. DOC, art. 263 : dommages-intérêts pour inexécution. | Contrat d'infogérance : clauses de sécurité et de MFA, sauvegarde, plafond de responsabilité, assurance RC du prestataire. |
| Messages minimisant l'incident ; renvoi aux « canaux contractuels ».                                              | DOC, art. 231 : exécution de bonne foi (information, coopération).                                                                                                                                                                        | Clause de notification d'incident ; droit d'audit ; remise des journaux.                                                   |

## 04 Enjeux liés aux données potentiellement exposées

| Source probable           | Données                     | Personnes             | Enjeu                                               |
|---------------------------|-----------------------------|-----------------------|-----------------------------------------------------|
| Paie (PAIE-01)            | Salaires, RIB, CIN, CNSS    | Salariés              | Fraude bancaire, usurpation d'identité              |
| Dossiers RH               | Contrats, arrêts de travail | Salariés              | Données de santé = <b>sensibles</b> (09-08, art. 1) |
| Finance, ERP, facturation | IBAN, factures, contacts    | Fournisseurs, clients | Fraude au virement (déjà tentée, A-23)              |

Pour l'entreprise : sanctions 09-08 (art. 58, amendes doublées par l'art. 64), réclamations clients, chantage à la publication. **Manquent** : liste des fichiers sortis (un volume ne suffit pas) et explication de l'écart 12,5 Go (A-02) / 117,8 Go (A-03).

## 05 Éléments nécessaires à un arbitrage sur la rançon

| Élément                            | Ce qui est établi                                                                                                                                              | Ce qui manque                                                                                    |
|------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Affirmations de l'attaquant</b> | Chiffrement confirmé (23 / 40, A-13) ; sortie de données avérée mais contenu inconnu ; sauvegardes en ligne neutralisées (A-05).                               | État des bandes hors ligne : la suppression des clichés ≠ destruction de toutes les sauvegardes. |
| <b>Capacité de reprise</b>         | Dernier travail Veeam réussi J-4 (à confirmer) ; SCADA et DC-02 intacts.                                                                                       | Test de restauration ; outil de déchiffrement public (No More Ransom).                           |
| <b>Cadre juridique</b>             | Aucun texte trouvé interdisant de payer ; l'Office des changes (2017) juge les transactions en monnaies virtuelles contraires à la réglementation des changes. | Avis juridique ; position de la police.                                                          |
| <b>Assurance et effets</b>         | Payer ne supprime aucune obligation (DGSSI, CNDP, clients) et ne garantit ni déchiffrement ni suppression des données.                                         | Couverture extorsion ; accord de l'assureur.                                                     |
| <b>Échéance</b>                    | 48 h à partir de l'apparition de la note (J2).                                                                                                                 | Heure exacte de départ (A-04).                                                                   |

**Sources** : loi 05-20 ([bwcmplementation.org/sites/default/files/resource/loi%2005-20.pdf](http://bwcmplementation.org/sites/default/files/resource/loi%2005-20.pdf)) · loi 09-08 et sanctions ([cndp.ma](http://cndp.ma)) · code des assurances, loi 17-99 ([acaps.ma](http://acaps.ma)) · DOC art. 230, 231, 263, 269 ([village-justice.com](http://village-justice.com)) · Office des changes 2017 ([telquel.ma](http://telquel.ma)).